Threat evolution in Q4 2018

GROUP-IB
GLOBAL CYBER SECURITY COMPANY

Table of contents

Introduction 3
Executive summary 4
Forecasts for Q1 2019 7
APT targeting the Financial Sector 8
Financial Threats 13
Malware for Android 14
Banking threats for PC 17
Exploits and vulnerabilities 23
Attacks on ATM and POS terminals 24
State-sponsored APT 25
Data leaks 39

Introduction

Every quarter Group-IB releases a report on the development of high tech cyber-crime, featuring new tendencies, emerging trends and predictions on the cyber-threat landscape.

The most dangerous threats have been attacks on the financial sector. This report features threats with a particular focus on Europe, Russia, the USA, Canada, and Australia. This document also provides a comprehensive description of threats to governments, including targeted attacks supported by government and significant data leaks.

To collect data and inform our clients, we analyze various botnets and malware while conducting incident response, monitoring underground forums and accumulating information on new trends, threats and data leaks. Every day we research thousands of compromised credentials, bank card numbers, hackers' accounts, messages and announcements on the dark web as well as tens of thousands of attacks, which enables us to promptly notify you of threats targeting your company and clients.

Executive summary

Targeted attacks on the financial sector

In Q4 2018, the following APT campaigns against financial institutions were detected:

- Cobalt continued their attacks. Their campaigns delivered both documents with malicious macros and exploits. In particular, in December 2018, they used a new exploit for the CVE-2018-15982 vulnerability in Adobe Flash Player. In the identified attacks, the Cobalt Strike beacon or CobInt malware was downloaded on the victim's machine. During the reporting period, we did not see the attackers using their JavaScript Backdoor. Their victims include banks in Europe, the CIS, and America. One of the campaigns purported to be from the Central Bank of Kazakhstan. Also, the emails posed as SWIFT, SEPA, Wells Fargo, Unistream and Kassa Nova commercial banks.
- The Silence group was very active. They launched multiple phishing campaigns acting as commercial banks and the Central Bank of the Russian Federation. The emails were written in Russian or English and were sent to British financial companies.
- The MoneyTaker group conducted attacks on banks in the CIS. In October, a campaign was observed purporting to be from the Financial Sector Computer Emergency Response Team FinCERT. In December 2018, the emails were sent from the Alfa Capital's mail server to the CIS organizations. The attackers used Meterpreter.
- In early November 2018, the Fin7 group launched attacks targeting the restaurant industry.
- Lazarus attacked financial institutions in Latin America. Researchers also discovered a new global campaign, which involved a new modular backdoor Rising Sun. In addition, details of the FASTCash Trojan, which has been used in attacks on ATMs since 2016, was disclosed.
- Details of the attack campaign, dubbed DarkVishnya, targeting banks in Eastern Europe, was uncovered.

Financial Threats

- RTM was delivered through spam campaigns to attack bank clients in the CIS;
- AndyBot (aka Gustuff bot) Android Trojan actively attacked banks in Australia. The malware was distributed through phishing SMS messages. Experts found that, in addition to the basic functionality, Gustuff has a unique feature which not been seen previously in malicious programs for Android—an Automatic Transfer System (ATS) mechanism, which silently and invisibly automate the execution of bank transfers.
- Also, foreign banks were attacked by the “Red Alert” banking Trojan;
- Trickbot attacked financial institutions in the United States, Canada, Britain, Spain, Germany, Australia, and Bulgaria;
- Group-IB specialists identified the server used by the MageCart group, which became famous after a successful attack against British Airways that compromised hundreds of thousands of credit cards. We also observe that the malicious software used in such attacks (credit card sniffers) is actively being sold on underground resources. In December 2018 a sniffer called “Inter” went on sale;
- A new password stealer Loki Bot v2.1 was put up for sale on the dark web;
- Also, a new loader dubbed Amadey went on sale;
- Researchers identified new vulnerabilities that may be exploited by attackers. CVE-2018-10933 is a vulnerability in libssh versions 0.6 and above; CVE-2018-8453 is a vulnerability in win32k.sys in all supported Windows versions. We recommend that you update your software to the latest version;
- The developer of the AZORult stealer (CrydBox) posted a message on the forum, saying that he stopped selling this tool;
- Emotet continued to be actively used to deliver other malware;
- Gozi banking Trojan (aka ISFB/Ursnif/Dreambot) again attacked banks in Australia and Japan;
- Identified samples of the BackSwap malware were used to attack banks in Spain;
- The most active mobile banking Trojans in Russia were Asacub, Agent, BID, Flexnet;

- Ramnit was actively used in attacks against targets in Italy, UK, and Japan;
- Gootkit appeared after a break to attack banks in Canada;
- ICEDID malware was active, targeting banks in the USA, Canada, and the UK;
- The number of Qbot attacks has decreased significantly;
- We did not detect any TinyNuke activity;
- Jackpotting attacks on ATMs were identified in Ukraine.

Data Leaks

- Quora's knowledge sharing service administration announced a data leak of 100 million users as a result of a hacker attack.
- HSBC has said about 1% of % of its US customers' bank accounts were hacked in October.
- The personal data of 9.4m Cathay Pacific passengers has been stolen in a cyber attack on the Hong Kong airline.
- The international hotel chain Marriott suffered a massive data breach affecting the records of up to327 million guests.
- In early October, the US Department of Defense suffered a major breach of employee's personal and financial information, according to reports. The incident may have affected as many as 30,000 civilian and military personnel.

Threats to the Government Sector

Governments are always going to be under the threat of cyber espionage and in some cases suffer attacks on critical infrastructure. Group-IB specialists perform an independent analysis of such threats and are well-informed about the results of global expert studies. In Q4 2018 the following active APT campaigns against state institutions were detected:

- The APT29 group resumed their activity by conducting attacks against organizations in the United States, Europe, Hong Kong, India, and Canada. The attempts involved a phishing email that delivered Cobalt Strike Beacon.
- The APT28 group conducted several large-scale operations: they attacked government organizations in Central Asia and Europe using an updated version of Zebrocy malware; conducted a global phishing campaign dubbed 'Dear Joohn' against government organizations in North America, Europe, and the CIS, using different versions of Zebrocy (in Deplhi, C#, VB.NET) and a new malware Cannon; launched two phishing campaigns against European military organizations, which delivered Gamefish malware.
- DarkHotel APT group conducted phishing attacks against high-ranking political figures. The emails delivered decoy documents related to the Korean Peninsula issues, and installation of Syscon backdoor.
- The Iranian MuddyWater group actively attacked victims in the Middle East. The group continues, since the moment of its first activity, to conduct attacks based on spear phishing with malicious content and using its main backdoor on PowerShell. Only the delivery methods, and the masking of the boot loaders and the payload are changing. Researchers from Symantec found traces of the effects of two groups MuddyWater and Fancy Bear in the local network of the embassy of one oil-producing country in Brazil.
- In October 2018, ESET researchers published reports, detailing GreyEnergy and Exaramel backdoors. Security specialists provided evidence the GreyEnergy group is strongly related to the BlackEnergy and TeleBots APT. ESET researchers also discovered a worm that appears to be the predecessor of NotPetya, and which they call Moonraker Petya.
- A Vietnamese group OceanLotus performed a new watering hole campaign. The attackers have stepped up their game to complicate and slow down analysis of their malicious framework.
- The large-scale activity of APT10 against the UK is revealed: attacks within the framework of the operation "Cloud Hopper", attacks using Cobalt Strike, attacks using crypto-mining software.

- Unknown cybercriminals launched attacks on the energy, government, telecommunications and oil and gas industries using the Shamoon 3 wiper.
- Security researchers observed Charming Kitten's attempts to break into the email accounts of US Treasury officials tasked with enforcing economic and military sanctions against the Islamic Republic of Iran.
- Chinese cybercriminals gained access to the European Union's diplomatic correspondence network.
- Experts observed the exploitation of the zero-day vulnerability CVE-2018-15982 in an attack targeting a Russian state healthcare clinic "Polyclinic No. 2" of the Administrative Directorate of the President of the Russian Federation.
- In Q4 2018, the Donot APT group was observed attacking a Pakistani businessman who is working in China. First attack of this campaign took place in May 2018.
- Researchers detected a cyber espionage campaign, dubbed Stolen Pencil, which was targeting academic institutions in the field of biomedical engineering.
- In November 2018, Gamaredon threat group continued their malicious campaigns against state authorities of Ukraine using a modified version of Pterodo malware.
- The Kimsuky Group continued their malicious activities against South Korea. This time the group performed a cyber espionage campaign focused on the innovations and developments of South Korea.
- In Q4 2018, another North Korean cybercrime group, APT37, was active. The attackers exploited an unknown vulnerability in the Hancom Office suite, targeting South Korean activists. Researchers also published a report that attributed the NOKKI malware family to APT37 group. The malware was used in recent attacks containing politically-motivated lures targeting Russian and Cambodian speaking individuals or organizations.
- Researchers have uncovered a previously unknown attack group named Gallmaker that is targeting government and military targets across the world.
- The Inception attackers launched a new wave of attacks on European targets using a new PowerShell backdoor dubbed POWERSHOWER.
- In Q4 2018, Sidewinder group resumed their cyber espionage activities using the CVE-2017–11882 vulnerability.
- APT-C-27 continued attacks on Arab countries. This time they masqueraded as The United Nations Relief and Works Agency for Palestine Refugees in the Near East (UNRWA).

Forecasts for Q1 2019

- Attackers will continue to actively use bank card sniffers. We expect that attacks similar to the attack on British Airways by the MageCart group will be repeated.
- After large-scale malicious campaigns targeting Russian financial institutions, purporting to come from the Central Bank of Russia and FinCERT, the Silence and MoneyTaker hacker groups may use this scheme in attacks on banks worldwide.
- The Cobalt group will conduct multiple attacks because we are already observing that they are preparing for them.
- Currently, all financially motivated hacker groups that organize targeted attacks on the financial sector are Russian-speaking. We expect similar groups to appear in Asian and Latin American hacker communities and they will start attacking regional banks.
- A new ATM hacking scheme, called FASTCash and used by the active North Korean APT group Lazarus, can be used in attacks on ATMs of international banks.
- Lazarus will also continue to attack banks and steal money through SWIFT, however we expect that they will attempt to perform attacks on card processing systems. Their main focus will be on countries in the Asia-Pacific region.
- Owners of RTM botnets can shift from attacks on legal entities to targeted attacks against banks in Russia and the CIS, as this is more beneficial for attackers.
- Backswap, Trickbot, IcedID will remain the most dangerous banking Trojans for the USA, Canada and Europe.
- AndyBot (aka Gustuff) and Red Alert Android banking Trojans will attack customers of western banks, while Asacub, Agent, BID, and Flexnet will be used in attacks in the CIS countries.
- Following the example of the Gustuff banking Trojan for Android, the function of mobile autofill may appear in other malicious programs for Android devices.
- The developer of the AZORult stealer announced that its sales would be terminated. However, we do not expect that in the next six months, the use of AZORult to compromise data will decrease significantly, since those who are using it now will continue to employ it further. In addition, some criminals still have a builder of this malware, so it will be distributed for some time in the underground community.
- Gozi will continue to attack financial institutions in Australia and Japan; Ramnit will also be active in Japan.

APT targeting the Financial Sector

GROUP IB

GLOBAL CYBER SECURITY COMPANY

APT name	Regions attacked	Related notifications	Operation start
Targeted attacks by the Cobalt group	Europe, CIS, Global	CP-1438-56 - CP-1438-64	2016

In Q4 2018, the Cobalt group continued their attacks. Except for the campaign of October 8, they used the CobInt malware as the final payload:

- On October 8, Cobalt sent mass emails acting as SWIFT. Messages were sent to members of a private database of SWIFT partners. The decoy document contained a macro compiled by the cactusTorch project, the code of which is publicly available. During the attack, the Cobalt Strike tool was downloaded.
- On October 30, Cobalt sent emails purporting to be from SEPA to financial institutions in Europe and the CIS. The letters contained links to download documents with either a macro or an exploit for the CVE-2017-8570 vulnerability in Microsoft Office.
- On November 19 and 21, 2018, the Cobalt group launched two massive phishing campaigns acting as UNISTREAM Commercial Bank
- On December 4, cybercriminals sent out emails to organizations in Europe and the CIS acting as Wells Fargo. The letters contained a link to a document with a malicious macro.
- On December 6, a mass mailing was detected from a compromised server of a commercial bank "Kassa Nova", during which the archive with a password was distributed. The archive contains an exploit document for a 1-day vulnerability in Adobe Flash Player CVE-2018-15982.
- On December 6, Cobalt arranged a mass mailing from the compromised server of the commercial bank Kassa Nova (Kazakhstan). The emails delivered a password-protected archive with an exploit for the 1-day vulnerability CVE-2018-15982 in Adobe Flash Player.
- On December 14, the Cobalt group sent out emails to banks acting as the Central Bank of Kazakhstan. The letter contained a link to download a document with a malicious macro.
- On December 18, Cobalt the Cobalt group launched a new attack on American financial institutions– again using email phishing and downloading the CobInt malware.

APT name	Regions attacked	Related notifications	Operation start
Targeted attacks purportedly conducted by MoneyTaker	CIS	CP-1774, CP-1824	October 2018

On 23 October, Group-IB detected mass emails to Russian banks sent from a fake FinCERT email address. The attack was most likely conducted by the MoneyTaker group. The message contained five attachments. Three out of five files were empty decoy documents, but two contained macros that would download the Meterpreter Stager in two versions for systems of different bitness.

On December 10, 2018, a malicious campaign, allegedly by the MoneyTaker group, was detected coming from the mail server mail.alfacapital.ru. The attachment contained a file with an embedded OLE object that will execute a JavaScript. The latter, in turn, will create three files with random names: Meterpreter Stager x64, Meterpreter Stager x86 and a decoy file. Then the script tries to open/run all files, regardless of the system bitness. Attackers use a self-signed SSL certificate for the C&C server.

MoneyTaker is a financially-motivated hacker group, which has been tracked since May 2016. The group primarily targets card processing systems in US banks and Russian systems of interbank transfers. Also, the group's arsenal includes a self-developed malicious program designed to attack ATMs, which was first discovered by Group-IB in May 2018.

APT name	Regions attacked	Operation start
Fin7	Latvia, Ukraine	November 2018

In early November 2018, the Fin7 group launched a new campaign that appears to have been targeting the restaurant industry. The initial decoy document “Oprosnik_new.doc” ("*New questionnaire*") was uploaded to VirusTotal from Latvia. The document protected with the password "goodmorning", was created 11.02.2018. It uses social engineering to convince the recipient to enable macros through the use of the images, logo and tagline of a newly launched, legitimate VPN tool InvinciBull by cybersecurity company Finjan. If the “enable macro” button is activated, the following obfuscated Macro runs and the next stage obfuscated JavaScript is extracted from the form caption. The JavaScript directly communicates with the C2 server. It executes the response which is yet another JavaScript command. During the first request, the MAC address and the computer domain are also delivered to the target C2. Researchers believe that the next stage is only delivered to specific targets based on domains as the data that is delivered in the first request is very limited.

During the analysis, specialists discovered another sample named “dinners.doc”, which was created on October 31, 2018. It was uploaded to VirusTotal from Ukraine. The document again uses the social engineering technique of spoofing a known and trusted entity to convince the victim to enable macros.

FIN7 is a financially-motivated Russian-speaking threat group that has been associated with malicious operations dating back to late 2015. FIN7’s primary method for gaining access to their targets is through social engineering. Throughout researchers’ tracking of FIN7 campaigns, the attackers have attempted to stay ahead of the game and thwart detection, using novel tactics and tools. The group has primarily targeted the restaurant sector in the U.S. and Europe. Their toolset includes the following programs: POWERSOURCE, HALFBAKED, BATELEUR, BIRDOG, and GRIFFON.

APT name	Regions attacked	Related notifications	Operation start
Lazarus	Global	CP-1788	2016

Experts have discovered a malicious DOC file, which was compiled in late October 2018. The document is written in English and tricks the user into running a malicious macro. The macro executes the command to connect to a specific website and install additional malicious files. The malicious code attempts to communicate with four C&C servers using two Korean (KR) and two US IPs. Some of the IP addresses are used not only as C&C servers, but also as a storage for malicious files.

Malicious files with RAT functionality collect information from the machine and send it to the C&C server. In response, the server sends additional files. At the reporting time malicious files were detected in South Africa, and, purportedly, in Israel. Malicious documents carried the author’s name Richard.

In December 2018, McAfee reported a global effort to infiltrate at least 87 organizations. According to McAfee's analysis, this campaign delivered the Rising Sun implant, which is believed to be an evolution of the Lazarus backdoor Duuzer.

This implant starts by building its imports via dynamic API resolution: LoadLibrary()/GetProcAddress().The library and API names are hardcoded as DWORD/WORD values in the implant and comprise a blob of bytes 0x147 bytes in size. This blob of data is decrypted using a simple single-byte XOR scheme with the key 0xC8. This scheme used for building the Library and API names is a variant of the byte-chunk string-construction technique often used by Lazarus implants.

The Lazarus group used a modular backdoor in their September 2018 attacks against financial institutions in Latin America, employing a complicated technique that involves three major components:

- **AuditCred.dll/ROptimizer.dll** – loader DLL that is launched as a service
- **Msadoz.dll** – encrypted backdoor
- **Auditcred.dll.mui/rOptimizer.dll.mui** – encrypted configuration file

If successfully installed, the Msadoz.dll backdoor is able to perform the following functionality:

- Collect file/folder/drive information
- Download files and additional malware
- Launch/terminate/enumerate process
- Update configuration data
- Delete files
- Inject code from files to other running process
- Utilize proxy
- Open reverse shell

In addition, in Q4 2018, researchers uncovered the FASTCash malware that Lazarus Group had been using since 2016 to empty millions of dollars in cash from ATMs.

In order to permit their fraudulent withdrawals from ATMs, the attackers injected the malicious code into a legitimate process on application servers running unsupported IBM Advanced Interactive eXecutive (AIX) operating system versions. The malicious executable contains logic to construct fraudulent ISO 8583 messages. ISO 8583 is the standard for financial transaction messaging.

Once installed on the server, Trojan.Fastcash will read all incoming network traffic, scanning for incoming ISO 8583 request messages, and when a Primary Account Number (PAN) used by the attackers is detected the malware will attempt to modify these messages. The messages are modified depending on each victim organization, the malicious code will generate a fake response message approving fraudulent withdrawal requests. In this way, the money mules managed to withdraw money via ATMs approved across the world.

The Lazarus group, also known as Dark Seoul Gang/HIDDEN COBRA/Guardians of Peace, started its operations back in 2007. Members of this group are believed to originate from North Korea.

APT name	Regions attacked	Operation start
DarkVishnya	Eastern Europe	2017

Kaspersky Lab published results of their investigation into a series of cybertheft incidents that they were invited to research in 2017-2018. The attack campaign, dubbed DarkVishnya - dark cherry - has targeted banks in Eastern Europe.

Analysis showed that each attack had a common springboard: an unknown device directly connected to the company's local network. In some cases, it was the central office, in others a regional office, sometimes located in another country.

According to experts, each attack can be divided into several identical stages. At the first stage, a cybercriminal entered the organization's building under the guise of a courier, job seeker, etc., and connected a device to the local network, for example, in one of the meeting rooms. Where possible, the device was hidden or blended into the surroundings, so as not to arouse suspicion. In the cases Kaspersky Lab researched, the hackers used one of the three tools:

- netbook or inexpensive laptop
- Raspberry Pi computer
- Bash Bunny, a special tool for carrying out USB attacks

At the second stage, the attackers remotely connected to the device and scanned the local network seeking to gain access to public shared folders, web servers, and any other open resources. The aim was to harvest information about the network, above all, servers and workstations used for making payments.

Having succeeded, the cybercriminals proceeded to stage three. Here they logged into the target system and used remote access software to retain access. Next, malicious services created using msfvenom were started on the compromised computer. Because the hackers used fileless attacks and PowerShell, they were able to avoid whitelisting technologies and domain policies. If they encountered a whitelisting that could not be bypassed, or PowerShell was blocked on the target computer, the cybercriminals used impacket, and winexesvc.exe or psexec.exe to run executable files remotely.

Financial Threats

GROUP IB

GLOBAL CYBER SECURITY COMPANY

Malware for Android

Threat name	Detection	Regions attacked
AndyBot aka Gustuff Bot	2017	Australia, USA, Europe

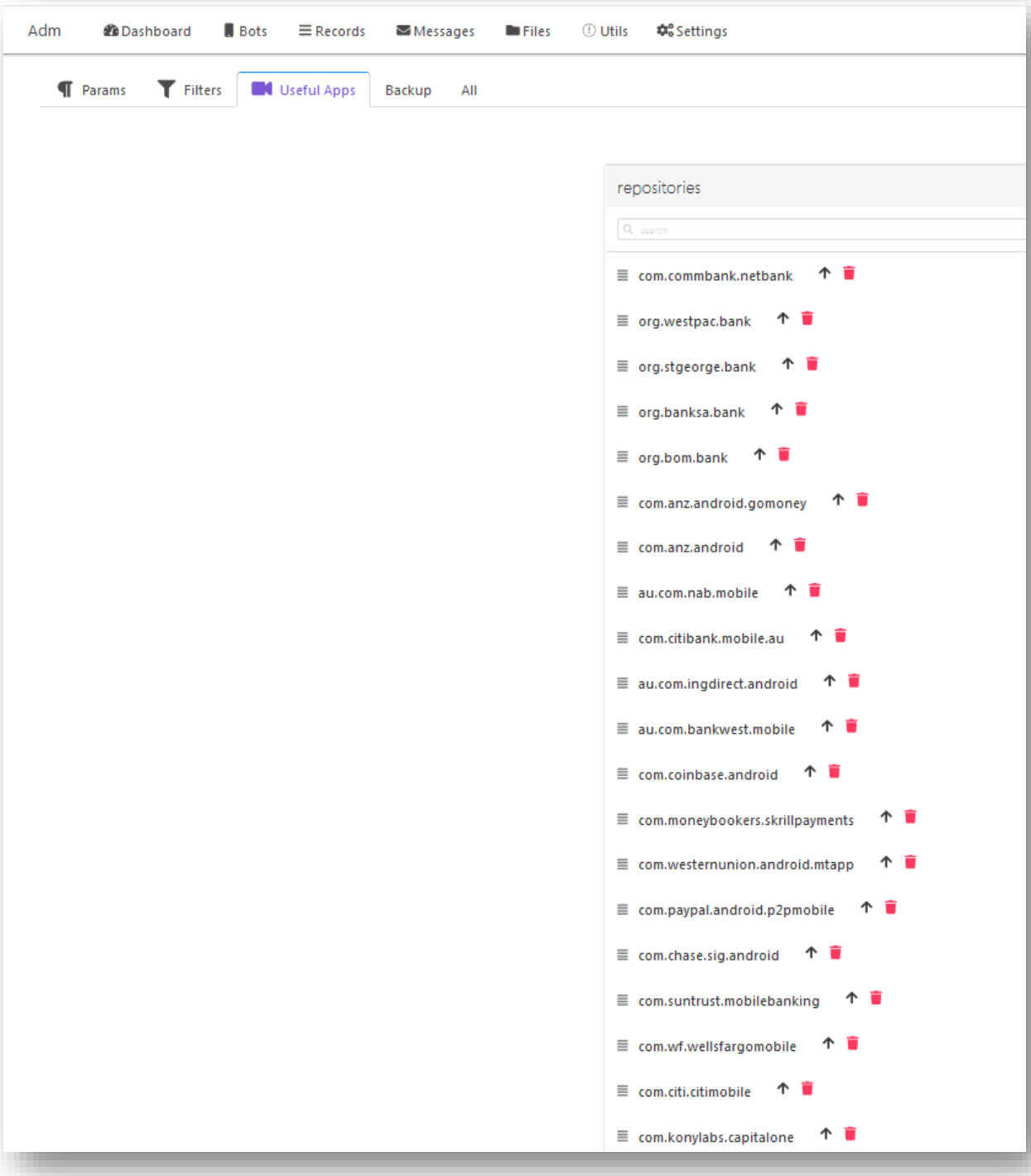
An updated version of AndyBot (dubbed Gustuff Bot by its author), a Trojan for Android, appeared on an underground forum in early April.

In November, researchers discovered that the Trojan was actively used to attack clients of Australian banks. The malware was delivered through SMS spam.

Group-IB experts have analysed malware samples. Analysis shows that their functionality corresponds to the description provided by the seller nicknamed bestoffer on the underground forum. We have also discovered that Gustuff has a unique feature which not been seen previously in malicious programs for Android—an Automatic Transfer System (ATS) mechanism, which silently and invisibly automates the execution of bank transfers.

The program has the following features:

- Display fake overlay pages of targeted banking apps
- ATS mechanism – on command it changes the values of fields in banking applications
- Send SMS messages and USSD requests to the C&C server
- Start a SOCKS5 proxy server
- Following links
- Display push notifications
- Upload information about the infected device to the C&C server
- Send the victim's files, including photos, to the C&C server
- Block an infected device
- Identify the installed anti-virus
- Reset the device to factory settings



Screenshot –Gustuff bot control panel

Threat name	**Detection**	**Regions attacked**
Asacub	2014	Russia

Asacub is distributed through phishing SMS messages. In Q4 2018, hackers actively spread new versions of Asacub – 5 and 6. The new versions are developed in C ++, instead of Java. That said, some of the functions of the old version were lost, but they will probably be restored soon. Currently, the application can intercept SMS messages, block incoming calls, display phishing windows (web injections), receive a contact list, make USSD

requests, send SMS messages to any number, or to the entire list of contacts on the device, and also receive a list of installed applications.

To perform all available capabilities, the malware asks the victim to grant it additional permissions. Once granted necessary rights by the user, the Trojan obtains the full control of the device. From then, it is very difficult to remove the application, because it blocks any victim's attempts to use the application manager or anti-virus solutions (the most popular).

Threat name	Regions attacked	Detection
Red Alert	Global	May 2017

Currently, the Red Alert Android banking Trojan is quite popular and often purchased on underground resources. At a relatively low price, the client gets an effective malware with a large set of fake pages for attacks on banks worldwide, as well as for cryptocurrency wallets. The author nicknamed Sochi is constantly updating the malware - in March 2018 Red Alert Version 2 was released. The list of attacked banks is expanding as well. With a list of over 200 targets, criminals do not limit themselves to banking apps, but expand their non-banking targets including mail clients, cryptocurrency apps and various payment systems.

Threat name	Regions attacked	Detection
Agent.BID	Russia	August 2015

Agent.BID is an Android banking Trojan with web injection functionality. It suspended its activity in late 2016. A new campaign using the Trojan has been active since Q2 2018.

The Trojan displays fake web pages posing as legitimate banking apps, which enables attackers to steal online banking credentials and bank card data. It is interesting to note that in Q3, the botnet based on Agent.BID greatly increased in size, in Q4 it also grew, but not significantly.

Threat name	Regions attacked	Detection
FlexNet	Russia	2014

The Trojan requests device administrator privileges. The text of the request is masqueraded as the Google Play Agreement, which distracts the user and leads to the confirmation of rights.

On command from the C&C server the application can:

- change the address of the C&C server
- send an SMS message to the specified number
- send spam messages with the specified text
- forward SMS messages to the C&C server
- reply to SMS messages and delete them to hide from the user
- run USSD requests
- create a scheduled task - setting up a command template for new bots, taking into account the operator and the country.

Also, Group-IB specialists determined that authors added phishing dialogs disguised as popular applications to the recent version of FlexNet. The fake overlay windows are designed to receive victim's bank card data.

AliExpress
Alpha
Avito
Google Play

MyNewAlpha
telecard
ВТБ24 (VTB Bank)
Сбербанк (Sberbank)
Uber

Banking threats for PC

Threat name	Detection	Regions attacked	Related notifications
MageCart	2018	Global	CP-1773

Group-IB specialists detected the server used by the MageCart group, which became famous after a successful attack against British Airways that compromised hundreds of thousands of credit cards. This server has multiple related domain names, which were registered by the attackers as names of legitimate websites with other TLDs. During the first campaign, the group created a new website, which stored a packet sniffer for each new compromised online shop. During the campaign, the group used only four websites for storing sniffers. Group-IB specialists detected more than 217,000 entries containing compromised payment information, including comprehensive information on victims' credit cards, phone numbers, email addresses, and home addresses.

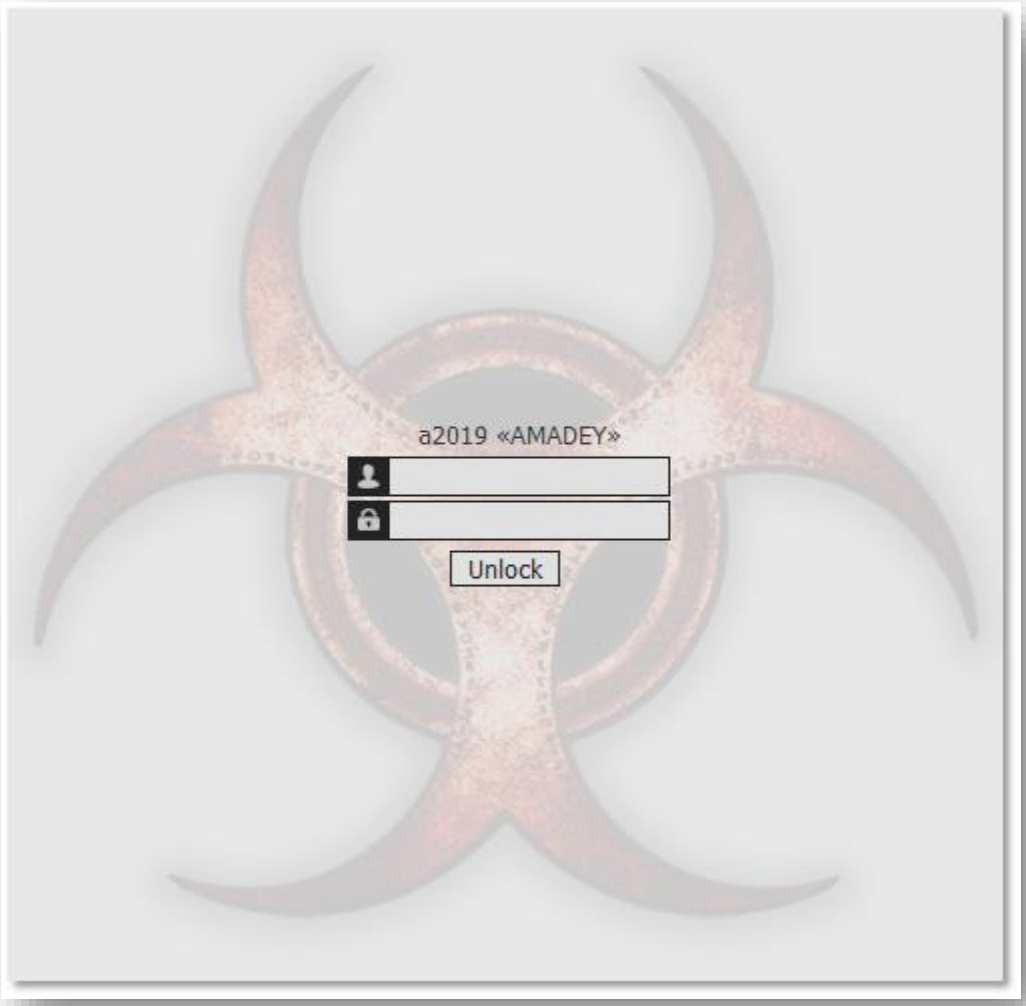
We are continuing to analyze such attacks and various credit card sniffers.

Threat name	Detection	Regions attacked	Related notifications
Loki Bot	2015	Global	CP-1770

On October 10, 2018, on the underground forum "exploit.in", a user named "carter" published an announcement about the sale of "Loki Bot v2.1". Loki PWS (Password Stealer, aka Loki Bot, Loki-bot, LokiBot) first appeared on underground forums in 2015. Loki PWS is designed to steal authentication data and cookies saved in browsers. In addition, the malware can steal logins/passwords from Cryptocoin wallets, email clients, FTP clients, VNC clients, and poker clients. It has filegrabber, keylogger, VNC, Proxy, formgrabber (FF, Chrome, IE, Edge, and Opera) and resident loader modules. Loki PWS sends stolen information to the C&C server via HTTP POST. The Trojan is written in C++ and targets the following versions of Windows: XP, Vista, 7, 8, 8.1, 10; and Linux. In the new version, the administrative panel was updated; DDoS, Miner and Ransomware modules were added. There was also an updated list of supported browsers, FTP, VNC, email clients, etc. The full description can be found in the appendix. Loki PWS has a modular structure. The full price of the Trojan including modules is $2,200.

Threat name	Detection	Regions attacked	Related notifications
Amadey	2018	Global	CP-1782

A threat actor with the nickname InCrease published an announcement about the sale of the new malware Amadey on an underground hacker forum. The main features of this loader are: small size (47 kb), antivirus protection bypassing, and full compatibility with all versions of Windows OS NT 32/64. The loader can be used by fraudsters to send malware to POS terminals since most electronic cash systems are based on Windows. Thereafter, hackers are able to collect card dumps and PIN codes from infected machines. Judging by the announcement, anti-virus detection and stability tests were performed according to the following algorithm: "This test was performed with every of twenty basic antiviruses: Avast, Avira, Kaspersky, NOD32, Panda, DrWeb, AVG, 360 TS, Bitdefender, Norton, Sophos, Comodo." All declared functions were performing well with these antiviruses enabled (except for Comodo).

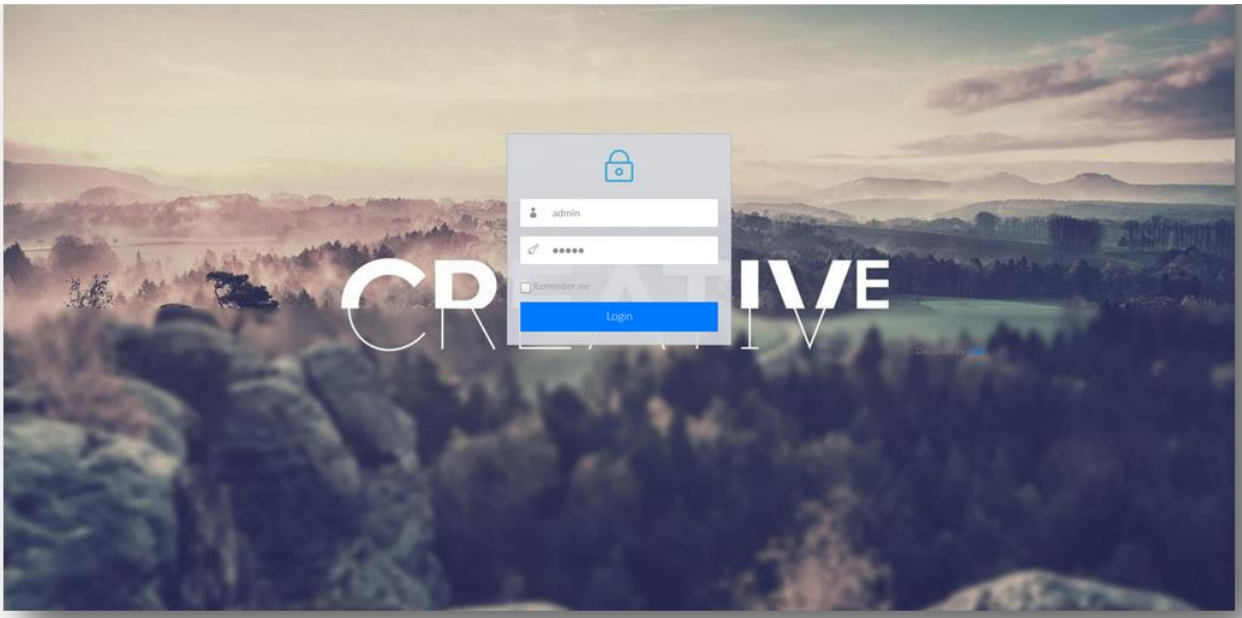


Screenshot – Control panel of the Amadey loader

Threat name	Detection	Regions attacked	Related notifications
Ariel	2018	Global	CP-1800

In November 2018, a system designed to conduct spear-phishing attacks, named Ariel, first appeared on an underground forum. This phishing kit uses fake landings, offering victims to “update” their software to view the contents of a document or a browser page. As the seller mentioned in the topic, the phishing kit includes landing pages for Microsoft Word, Excel, Adobe Flash, PDF Plugin, as well as updates for fonts and browsers.

It is worth noting that this tool was observed in email campaigns targeting banks in December 2018.



Screenshot – Ariel control panel

Threat name	Regions attacked	Detection
ICEDID	USA, Canada, UK	2017

Security specialists originally discovered this banking Trojan in late 2017. This malicious program may be employed to steal financial information and conduct targeted attacks. In Q4 2018, it was again distributed using Emotet, another well-known banking Trojan, as well as through phishing campaigns with malicious documents containing macros that download and execute ICEDID on the victim's device.

ICEDID has a modular structure and incorporates techniques of the infamous Zeus Trojan, including web injections, the ability to embed code into processes, and data theft. One of its distinctive features is the ability to deploy a proxy server on an infected machine and redirect all Internet traffic using this server.

The identified ICEDID samples are designed to target the following banks in the US, Canada, and the UK:

HSBC Bank
JPMorgan Chase
Citibank
Bank of America
The Synovus Financial Corporation
Toronto-Dominion Bank (TD BANK)
Chase Bank
Charles Schwab Corporation
Fifth Third Bank (53 bank)
Capital One
Wells Fargo
Post Oak Bank (US)
Halifax
TSB Bank
Usbank
Unionbank (US)

Threat name	Regions attacked	Detection
Gozi (ISFB, Ursnif, Dreambot)	Australia, Japan	2007

In Q4 2018, Group-IB discovered Gozi samples attacking banks in Australia and Japan.

Examples of attacked banks in Australia:

ANZ
Bankwest
Bendigobank
Commonwealth bank
NAB
StGeorge
BankSA
Bankofmelbourne
Suncorpbank
Westpac
Australianmilitarybank
Adelaidebank
Bankvic
Bananacoast Community Credit Union
Regionalaustraliabank
Customsbank
Fmbank
Gcmutualbank
Humebank
Unitybank
Mycreditunion

Examples of attacked banks in Japan:

Shinkin bank
The Bank of Tokyo-Mitsubishi UFJ
Aeon Bank
Credit Saison
Daishi bank
Hokkoku bank
Resona Bank
Tsukuba bank
Awa bank
Yamagata Bank
Japan Post Bank
Tsukuba Bank
Miyazaki Bank
Hiroshima Bank
Rakuten Bank
Idemitsu Credit Co.
Japan Net Bank

Threat name	Regions attacked	Detection
Trickbot	USA, Canada, UK, Spain, Germany, Bulgaria, Australia	Fall 2016

Trickbot is a banking Trojan that has a similar functionality to the Dyre (Dyreza) malware. It is distributed through spam emails or using an additional malware Emotet.

The samples detected in Q4 2018 are targeting the following banks:

HSBC Bank
Scotiabank
Toronto-Dominion Bank (TD BANK)
Bank of Montreal
Royal Bank of Canada
ABN AMRO Bank
Caisses Desjardins
JPMorgan Chase
Usbank
Citibank
Bank of America
American Express
Barclays
BB&T Bank
Bank of Scotland
Deutschen Bank
Lloyds Bank
Deutsche Postbank AG
Sparda Bank
Ulster Bank
Banco Bilbao Vizcaya Argentaria (BBVA)
Laurentian Bank of Canada
Blockchain.info
First Citizens Bank
Danske Bank
TSB Bank
Huntington Bancshares, Inc.
The National Bank of Canada
Capital One
Citizens Financial Group
Chase Bank
Canadian Imperial Bank of Commerce (CIBC)

Charles Schwab Corporation
Comdirect Bank AG
Commerzbank
Fifth Third Bank (53 bank)
Halifax
KeyBank
Sparkasse
Commonwealth Bank of Australia
Regions Financial Corporation
Unicredit Bulbank (BG)
Suntrust
Tesco Bank
PNCbank
Wells Fargo

Threat name	Detection	Regions attacked
RTM	2015	Russia

The modular Trojan is written in Delphi. The Trojan is designed to attack RBS and payment systems. The last detected sample of the Trojan searched for the following RBS systems on the infected machine: BSS_PC, Faktura, HandyBank, QiwiCashier, Raiffeisen, RosBank, SberBank_BO, SberBank_Fiz, SberBank_PC, VTB24.

The RTM group uses the main control panel and a separate Proxy panel for banks with which they use a specific technique – all requests are forwarded to phishing servers, where traffic is proxied.

In Q4 2018, we observed multiple email campaigns distributing RTM. We tracked these mailouts almost every day. The emails were sent to Russian-speaking legal entities.

Name	Detection	Countries attacked
Gootkit	2014	Canada

Gootkit banking Trojan has the functionality to record video, take screenshots, change web pages using web injections, redirect victims to phishing resources, install keylogger, and block URLs.

In Q4 2018, researchers discovered samples attacking the following banks:

Bank of Montreal
Royal Bank of Canada
Scotiabank
Caisses Desjardins
Bank of America
Toronto-Dominion Bank (TD BANK)
The National Bank of Canada
Chase Bank
Canadian Imperial Bank of Commerce (CIBC)

Threat name	Detection	Regions attacked
BackSwap	March 2018	Spain

BackSwap is a banking Trojan that uses new techniques to bypass anti-virus solutions and steal money from bank clients. The Trojan was detected in Q2 2018, when it was delivered in spam emails targeting users in Poland.

BackSwap works with Windows GUI elements and simulates keystrokes in order to avoid detection and bypass the browser protection. The hackers who developed BackSwap were identified in January 2018, when the group was still distributing its earlier malware, e.g. a program stealing cryptocurrency by replacing wallet addresses in the clipboard.

Unlike other banking Trojans, BackSwap does not inject malicious code into browser processes, because it can be easily detected by anti-virus software. Instead, the malware hooks key Windows message loop events in order to inspect values of the window objects for banking activity. Once banking activity is detected, the malware injects malicious JavaScript into the web page, either via the browser's JavaScript console or directly into the address bar.

BackSwap samples, detected in Q4 2018, are targeted at the banks in Spain: Bancopopular, Sabadell, BBVA, Caixa.

Threat name	Regions attacked	Detection
Ramnit	Italy, UK, Japan	2010

The Ramnit banking Trojan was first discovered in 2010. The Ramnit botnet was disrupted in a joint operation of Europol and security firms in 2015.

However, the Trojan's activity did stop end there. It had been used to compromise credentials of banks in North America and Europe till early 2018. Then its activity had subsided again. However, in Q3 2018 we identified a new Ramnit botnet, which is still active. Analysis showed that the malware was used to attack the following financial institutions in Japan:

Credit Saison
Idemitsu Credit Co.
Mitsubishi UFJ NICOS Co
Aeon Bank
Life Card Co.
Pocket Card Co.
Cedyna Financial Corporation
Epos Card Co.
Rakuten
Sumimoto Mitsui Card Co.

The botnet has been active since late August 2018.

Also, in Q4 2018, we detected attacks using Ramnit against targets in Italy and the UK.

Threat name	Detection	Related notifications	Regions attacked
Credit card sniffers	September 2018	CP-1760	Global

On September 6, 2018, British Airways reported the compromise of user data on their website and mobile app. All users who booked their flights via the official website or mobile app from August 25 to September 5, 2018, were at risk. Attackers reportedly stole data of 380,000 users. The technical details of the attack were not disclosed. However, on September 11, the company RiskIQ published a research report stating that Magecart group was behind the attack. The attackers injected malicious JavaScript that collected user data from the airline's website. The mobile app also used the same script from the main website.

Group-IB experts have also begun their investigation. The preliminary research helped to reveal that credit card sniffers sold on underground resources could be used for such attacks. This class of malicious software is created to collect payment information during the payment process in online stores or various online services. The most popular targets for such attacks are the stores run by Magento and OpenCart. The installation of the malicious

script starts with getting access to the online store via the control panel or downloaded webshell. This gives an attacker the ability to modify the code of pages where the user is entering payment information: card number, expiration date, CVV and so on. After installing a sniffer, the attacker would have access to all payment information that was entered by the user in the store.

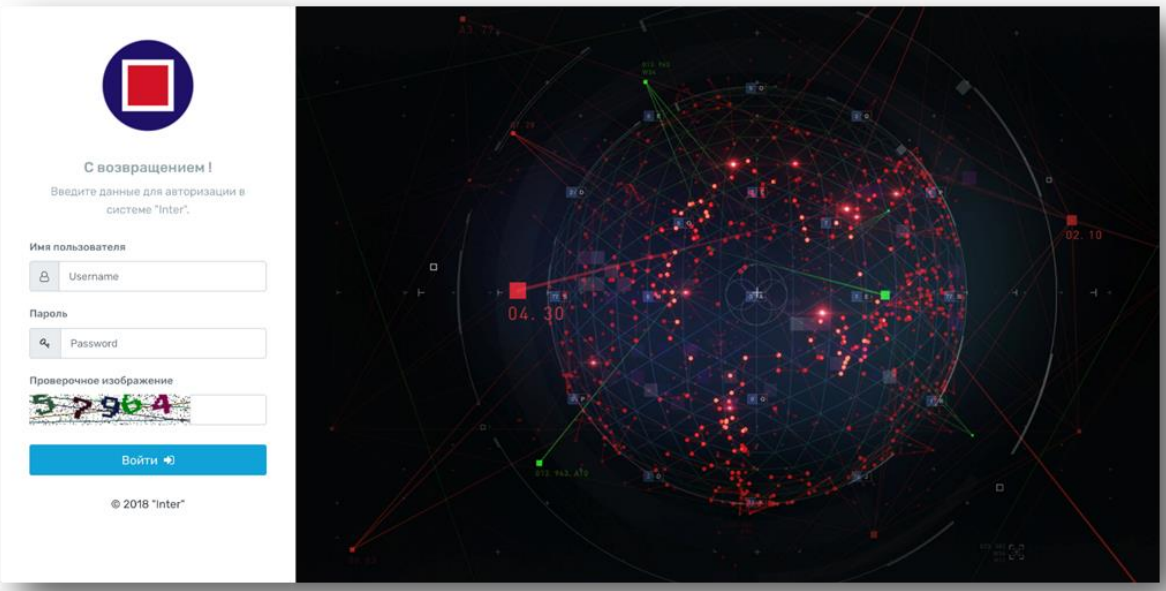
We are continuing our study.

Threat name	Detection	Related notifications	Regions attacked
Credit card sniffer "Inter"	December 2018	CP-1827	Global

One of the new credit sniffers that have appeared on the market is Inter. It is interesting to note that it was developed by a criminal named Sochi. He is the author of the "Red Alert" banking Trojan. In his new product, the malicious code is generated in the administrative panel that comes with the sniffer. Inter supports such CMS as Magento, OpenCart, osCommerce, and other similar systems that do not use the iframe element or redirect to an external site when entering payment information. The seller says that it is possible to customize the panel to support non-standard online stores, including those not using the iframe element.

The admin panel has the following features:

- Generation of JavaScript code with the parameters for the desired form of payment.
- Obtaining data from a sniffer and automated recognition of standard fields.
- Ability to add additional fields for processing.
- Additional features, such as card statistics, search, filtering, data export, etc.



Screenshot of the Inter admin panel

Exploits and vulnerabilities

Threat name	Detection	Related notifications	Regions attacked
CVE-2018-10933 vulnerability	October 2018	CP-1777	Global

On October 16, 2018, a critical vulnerability (CVE-2018-10933) was disclosed in libSSH, a library implementing the SSH2 protocol for clients and servers. The vulnerability allows an attacker to completely bypass the authentication step and connect to the server without providing any credentials. Group-IB experts have analyzed

servers where this vulnerability has not been patched. In total, we have detected 1,138 vulnerable servers, most of which are located in the United States.

Threat name	Detection	Related notifications	Regions attacked
1day exploit for CVE-2018-8453	December 2018	CP-1823	Global

On December 6, 2018, an announcement was published on an underground forum advertising the sale of an exploit for the CVE-2018-8453 vulnerability. This vulnerability is present in the win32k.sys driver in all supported versions of Windows. It allows an attacker to bypass Windows security mechanisms and enhance their privileges locally. Microsoft released a patch for this vulnerability on October 9, 2018.

In addition, a new vulnerability, CVE-2018-15982, was discovered in Adobe Flash Player, allowing attackers to execute remote code on the victim's machine. The PoC for this exploit was published on GitHub.

At the moment we do not observer an exploit for this vulnerability being sold on underground resources. However, we contacted the developers of the RIG Exploit kit and FalloutEK. They mentioned that this exploit was planned to be added to their packs, but, they say that the tests did not show a high level of their efficiency.

Attacks on ATM and POS terminals

- In early October 2018, an alert was issued by US-CERT, the Department of Homeland Security, the Department of the Treasury, and the FBI. According to this new alert, Lazarus group has been conducting "FASTCash" attacks, stealing money from Automated Teller Machines (ATMs) from banks in Asia and Africa since at least 2016. According to the U.S. government alert, one incident in 2017 saw cash withdrawn simultaneously from ATMs in over 30 different countries. In another major incident in 2018, cash was taken from ATMs in 23 separate countries. To date, the Lazarus FASTCash operation is estimated to have stolen tens of millions of dollars.

  Analysis by Symantec has found that Trojan.Fastcash has two primary functions:

  1. It monitors incoming messages and intercepts attacker-generated fraudulent transaction requests to prevent them from reaching the switch application that processes transactions.
  2. It contains logic that generates one of three fraudulent responses to fraudulent transaction requests.

  It will read the Primary Account Number (PAN) on all messages and, if it finds any containing a PAN number used by the attackers, the malware will attempt to modify these messages. How the messages are modified depends on each victim organization. It will then transmit a fake response message approving fraudulent withdrawal requests. The result is that attempts to withdraw money via an ATM by the Lazarus attackers will be approved.

  Currently, Group-IB specialists are examining this program to discover additional information.

- An ATM attack using a malware for ATM jackpotting was detected in Ukraine.

State-sponsored APT

GROUP IB

GLOBAL CYBER SECURITY COMPANY

APT name	Regions attacked	Operation start
APT29	Europe, USA, Hong Kong, India, Canada	November 2018

On November 14, 2018, APT29 conducted a global phishing campaign, targeting the USA (most victims), Europe, Hong Kong, India, and Canada. The victims included military and law enforcement media, media companies, defense contractors, pharmaceutical companies, analytical and research centers, educational institutions, local authorities, transport and public organizations, the hotel industry, private oil &gas and chemical companies.

To make their attacks appear legitimate, the attackers probably preliminarily compromised the mail server of the North Shore Health Hospital and Care Center and the corporate website of the consulting company JMJ Consulting. In their malicious emails, the hackers posed as a public affairs official at the U.S. Department of State, Susan Stevenson. Each phishing email contained a unique malicious URL, likely for tracking victim clicks. The links led to a ZIP archive that contained a weaponized Windows shortcut (LNK) file hosted on a likely compromised legitimate domain. This LNK file executed an obfuscated PowerShell command, which extracted the base64-encoded payload from it. Upon successful execution of the LNK file, it dropped the following files to the victim's system: a decoy document and a 64-bit BEACON loader DLL. The dropped BEACON loader DLL was executed by RunDll32.exe.

This LNK file executes an obfuscated PowerShell command, which extracts a base64-encoded payload from within the LNK file itself. This payload, which is another heavily obfuscated PowerShell script, is decoded and executed. The second script carves out two additional resources from within the .LNK file: a decoy document and a 64-bit DLL, which is Cobalt Strike BEACON, executed via RUNDLL32.EXE. Once connected to C&C, the malware installs the next-stage payload of Cobalt Strike.

APT29 (aka Dukes, CozyBear, Office Monkeys, CozyCar, Cozy Duke, Group 100, Cozer, Minidionis, SeaDuke, Hammer Toss, YTTRIUM) is a Russian-speaking hacker group, which has been active since 2008. This threat actor targets government ministries and related organizations (ministries, research centers, universities) in Western Europe, and to a lesser extent in the CIS, Turkey, Georgia, Asia, Africa and the Middle East.

APT name	Regions attacked	Operation start
APT28	CIS, Europe, North America, Central Asia	August 2018

In H2 2018, the APT28 group was very active on a global scale. The attackers significantly updated their malware and added a new tool, probably to make it difficult to detect.

In August 2018, the APT28 group deployed two new Zebrocy components and began using it in attacks against embassies, ministries of foreign affairs, and diplomats in Central Asia, Central and Eastern Europe. The updated version includes the following components: Delphi dropper, MSIL mail downloader, Delphi mail downloader, Delphi downloader, and Delphi backdoor. To infiltrate systems, the attackers send a phishing email with a malicious archive attached. After installation, the malware collects information and sends the encrypted files gathered previously to several addresses over SMTPS. The malware also uses POP3, interprets keywords from emails as commands, and sends back the result to the operator.

In October and November 2018, the APT28 group conducted a series of phishing attacks on government organizations in North America, Europe, and the CIS. Experts at Palo Alto Networks Unit 42 believe that these attacks are part of a global phishing campaign named “Dear Joohn”. The attacks share a common author name used in each of the delivery documents: Joohn.

The email account names, which were used to deliver phishing emails, visually look similar to legitimate government organization names or other trusted third-party entities. The delivery documents were functionally all the similar, using the remote template function in Microsoft Word to retrieve a malicious macro from the

first stage C2. The majority of delivery documents contain a generic lure image requesting the victim enable macros. As a payload, a Zebrocy version or a new Trojan called Cannon was installed. The Zebrocy variants delivered in this campaign were written in several different languages, including Delphi, C# and VB.NET. The Cannon version was written in C#.

Cannon is a malicious software, the first samples of which were discovered in 2018. It uses email accounts for its C2 communications. To obtain commands, the tool logs into an email account using POP3S and checks for emails with a specific filename that it will save to the system and execute. The results of command execution is carried out by using predefined email addresses. A sample of Cannon, written in Delphi, was also discovered, but its connection to the current campaign has not been established.

On November 30, 2018, APT28 launched a phishing campaign, purportedly targeting NATO members and European military organizations. Cybercriminals prepared the infrastructure in just a few days before the attack. Adversaries send phishing emails with NATO Simulation.doc containing malicious macros. On macro activation the instructions are designed to read specific xml node of the document itself through xmlParser and extract / decode the base64-encoded content. As a result, the Gamefish Trojan (aka Sednit, SofacyCarberp, Seduploader, and JHUHUGIT) is installed on the victim's machine. First, the malware performs Anti-VM technique and connectivity checks (requesting google.com). If the check shows that the connection is not established, then the Trojan will search for alternative ways. Gamefish has the ability to inject code into the browser, create screenshots, collect system information, etc. C&C communications are performed via HTTPS requests. The first request is sent after the malware has collected information about the victim's system and has checked if it is running in a virtual environment.

On macro activation the instructions are designed to read specific xml node of the document itself through *xmlParser* and extract / decode the base64 encoded content.

On December 20, 2018, researchers discovered a malicious decoy document named “UDS 2019 Current Agenda.doc” related to military/defense issues, which was probably used in the attack on an Eastern European country. The document contains a built-in macro, which retrieves Gamefish malware from a base64-encoded string directly, rather than through xml as in the attack of November 30, 2018.

The APT28 group (aka Fancy Bears, Sofacy Pawn Storm, Sednit, and Strontium) was first discovered in 2004. It is known for attacks on the political, media and military sectors.

APT name	Regions attacked	Operation start
DarkHotel	East and Southeast Asia	August 2018

In August 2018, researchers at Tencert Threat Analysis Center discovered two decoy files related to the Korean Peninsula issues (“Predict what’s next after the Singapore summit”, “Pompeo report”), which were later attributed to the DarkHotel group. These documents were probably used in attacks on high-level politicians and government authorities in East and Southeast Asia, which are related to the Korean Peninsula.

The attackers sent phishing emails with the decoy documents attached. To lure the victim into enabling macros, the font in the decoy document is intentionally modified to a very light color so that the user cannot read it, and when the macro is enabled, it will be displayed as black for reading. The macro ensures only a small part of the functionality, the main code is stored in hXXp://Bluemountain.1apps.com/1.txt, from where it is downloaded and saved as 1.bat. The main purpose of 1.bat is to download a .cab file depending on the version of the victim’s system. As a result of all the manipulations, the Syscon backdoor is installed. The backdoor is controlled over FTP protocol. The malware reads the C&C address, username and password from the configuration file. Then it collect system information on the victim’s machine using systeminfo/tasklist, saves the output in the temp.ini

file and uploads it to the C&C via FTP. Following this, the program executes commands received from the C&C server.

DarkHotel (aka APT-C-06, Tapaoux, Pioneer, Luder, Karba, Nemim, SIG25, Dubnium, Fallout Team) is a threat actor that has been active since at least 2007. They have primarily targeted high-profile hotel guests, and political figures, mainly, in Northeast Asia.

APT name	Regions attacked	Operation start
MuddyWater	Middle East, Russia, Austria	May 2018

In Q4 2018, MuddyWater conducted several aggressive campaigns.

The first campaign was observed from May to November 2018. Researchers tracked a large number of spear-phishing emails targeting government and military facilities, as well as telecommunications operators and educational institutions, mostly in Jordan, Turkey, Azerbaijan, and Pakistan. Similar emails were also detected in Mali, Austria, Russia, Iran, and Bahrain.

The group continued using spear-phishing emails containing Word documents with malicious macros. Once the user enables the macros, malicious files are added to autostart. The next time the user logs in, the dropped payload will be executed. In this attack, the group used a new method bypass AppLocker policies – using scrobj.dll.

In order for successful attacks to be repeated, the backdoor disables the security settings of Microsoft Office products by modifying the corresponding registry settings. There are also a number of features that threat actors to identify and filter infected users.

This version of the backdoor supports the following commands:

- Take screenshots;
- Receive PowerShell commands from C&C and execute them using DDE, COM, or MSHTA;
- Upload files to C&C;
- Destroy the victim's local disks;
- Reboot and shut down the victim's machine.

The attackers rely on a range of compromised hosts to deliver their attacks. To hide their traces, all found versions of the backdoor contain strings in broken Chinese.

In another campaign, which was observed from mid-September to mid-November, the group primarily affected victims in Pakistan, Turkey and Russia, in addition to the targeting of Saudi Arabia, Afghanistan and Jordan.

The telecommunications and IT services sectors were their main targets. The next most common group of victims was in the oil and gas sector. It is interesting to note that all victims in this group belong to one Russian firm that is active in the Middle East.

In this attack, the group used its POWERSTATS backdoor and some freely available tools. The researchers found a GitHub repository used by the group to store their scripts. They also discovered a link in to an account on Twitter with similar profile data. This Twitter account follows numerous security researchers, including those who have written about the group in the past.

This fact indicates that the group continues to monitor researchers in order to obtain more information about what they know at the moment. It should also be noted that, in addition to POWERSTATS, traces of the Fancy Bear group were discovered in the same local network, which is a rare coincidence.

In the operation observed in mid-November, the group sent out a fake resume application, or a letter from the Ministry of Justice in Lebanon or Saudi Arabia. The installation process of the POWERSTATS backdoor in this consists of 3 steps and begins with the launch of malicious macros in the bait documents.

Also in mid-November, researchers discovered documents in Turkish, which delivered the POWERSTATS backdoor to Turkish government organizations.

In these malware samples, the group used a cloud service provider, Dropbox, to control the backdoor instead of compromised websites. The program supports the following commands:

- upload a file to file hosting service
- download file from a hosting service
- remove persistence;
- execute command via Invoke Expression, a PowerShell command that runs commands or expressions on the local computer

MuddyWater is a threat actor that has been operating since 2017 mainly in the countries of the Middle East. The group uses a self-developed PowerShell backdoor, called POWERSTATS. MuddyWater is an active group, which constantly monitors incoming connections to their C&C servers and analyzes reports by security companies. During the research of one of the compromised website used by the group as a proxy server, in response the researcher received the string "Stop!!! I Kill You Researcher". In late 2018, Kaspersky Lab published its Security Bulletin 2018 detailing the top threats of the year. A comment appeared allegedly published by MuddyWater, in which they write that 3rd place is not fair to them, and researchers do not know much of their operations.

APT name	Regions attacked	Operation start
BlackEnergy	Ukraine, Poland	September 2017

In October 2018, ESET published a report describing a set of activity they called GreyEnergy, which is believed to be a successor to BlackEnergy group.

The attackers use two initial infection vectors. The first one is relevant for organizations with self-hosted web services. If such a public-facing web service is running on a server that is connected to an internal network, attackers will try to compromise it and then sneak inside the network. The second infection vector is the use of spear phishing emails with malicious attachments exploiting the CVE-2017-0199 and CVE-2017-11882 vulnerabilities.

CVE-2017-0199 enables the criminal to download and execute the Visual Basic script containing PowerShell commands when the user opens a document.

CVE-2017-11882 enables remote code execution on a vulnerable system.

Malicious documents drop “GreyEnergy mini”, a lightweight first-stage backdoor that does not require administrative privileges. After compromising a computer with GreyEnergy mini, attackers map the network and collect passwords in order to obtain domain administrator privileges. With these privileges, the attackers can control the whole network.

Once attackers are done with the initial network mapping, they can deploy their flagship backdoor – the main GreyEnergy malware. The GreyEnergy actors deploy this backdoor mainly on two types of endpoints: servers with high uptime, and workstations used to control ICS environments. To make communication with command and control (C&C) servers stealthier, the malicious actors may deploy additional software on internal servers in the compromised network, so each server would act as a proxy.

Each sample deployed in this way will have a unique hash. Having these hashes would allow the attackers to track whether the file was uploaded to one of the public "multi-scanner" web services, such as VirusTotal.

In April 2018, ESET researchers discovered new activity from the TeleBots group: an attempt to deploy a new backdoor, which ESET detects as **Win32/Exaramel**, in Ukraine. Their analysis suggests that this TeleBots' backdoor is an improved version of the main Industroyer backdoor – the first piece of evidence that confirms the link to the BlackEnergy group. Researchers discovered two variants of the backdoor: for Windows and Linux.

Another interesting fact is that the backdoor uses C&C servers with domain names that mimic domains belonging to ESET. Researchers found that the esetsmart[.]org and um10eset[.]net domains were used by Exaramel malware. If the malware operators want to exfiltrate files from the victim's computer, they just need to copy those files into the data sub-directory of the storage path defined in the configuration. Once the backdoor is about to make a new connection to the C&C server it will automatically compress and encrypt all these files before sending them.

In addition, in Q4 2018, ESET published a detailed analysis of the Moonraker worm, which is believed to have been a predecessor to NotPetya. According to the report, in December 2016, this worm was deployed against a small number of targets and had limited spreading capabilities, which is why it wasn't generally known to the security research community.

Moonraker Petya contains code that makes the computer unbootable. Unlike NotPetya, Moonraker Petya does not contain code that directly interacts with the MBR and the loader.

It is interesting to note that the payment instruction file contains a personal key encrypted with RSA-2048. In addition, it contains the same text and onion addresses as the original Green Petya. Green Petya is a variant of the malware family, which includes Red Petya, Mischa, and Goldeneye ransomware. Janus Cybercrime Solutions group is believed to be the author and distributor of the malware family. Interestingly, the decryption routine used by Moonraker Petya is very similar to a routine used by GreyEnergy in-memory-only DLL files. It seems that the attackers wanted to disguise usage of this malware as a Green Petya attack.

BlackEnergy Group, also known as SandWorm, Quedagh, TeleBots, GreyEnergy, has been active since at least 2010. The group has been targeting critical infrastructure facilities. Security experts believe that BlackEnergy group is backed by government agencies since the group has targeted and disrupted critical infrastructure facilities, causing huge losses (power outages in particular regions, loss of important data in the Ukraine's Ministry of Finance and the State Treasury), or organizations that work with strategic data used by threat actors in their own interests (historical information, map data).

APT name	Regions attacked	Operation start
OceanLotus	Southeast Asia	September 2018

Researchers have discovered a new watering hole campaign targeting several websites in Southeast Asia, and that is believed to have been active since September 2018. This campaign affected around 21 websites, some of which are particularly notable. Among the compromised websites were the Ministry of Defense of Cambodia, the Ministry of Foreign Affairs and International Cooperation of Cambodia and several religion-related or opposition Vietnamese newspaper or blog websites.

This campaign is believed to be an evolution of OceanLotus watering hole scheme researchers documented in 2017. Among the various improvements, they started using public key cryptography to exchange an AES session key, used to encrypt further communications, thus preventing security products from intercepting the final payload. They also switched from HTTP to WebSocket to hide their malicious communications.

Also, as in the previous attack, the attackers placed a malicious JavaScript on the compromised website. This time, each JavaScript code uses a series of techniques to evade detection.

Depending on the location of the IP address of the visitor, the first stage server, delivers either a decoy script or the first stage script. Not all the servers have a location check but when it is enabled, only visitors from Vietnam and Cambodia actually receive the malicious script. The first stage script performs several checks to evade detection. Then it connects to the C&C server to receive and execute a second-stage script.

The second-stage recon script builds a report, and sends it to the second stage C&C server. The communication is encrypted using an AES session key, generated by the server. The key is encrypted with an RSA 1024-bit public key and sent to the client. The generated report contains detailed information about the victim's browser and the website visited: the user-agent, the HTTP Referer, the local and external IP address, the browser plugins the browser's configured language preferences. Also, the script creates two unique identifiers per machine, which are probably used to identify users and track them across visits.

OceanLotus (aka APT32/APT-C-00/SeaLotus/Sinh Tử Lệnh) is believed to be a Vietnam-based APT group that has been around since 2010. This group uses self-developed backdoors, known vulnerabilities and a large number of C&C servers. The group reportedly operates from the territory of Vietnam and is backed by the Vietnamese government. The group has targeted foreign corporations with interests in Vietnam's consumer goods, manufacturing, and hospitality sectors. Among the victims, you can also find bloggers, journalists and other figures whose actions have been at cross-purposes with Vietnamese state interests.

APT name	Regions attacked	Operation start
APT10	UK	2016

In December 2018, NCSC released a report revealing details about the previously unknown attacks against the UK by the APT10 group.

NCSC specialists note that the campaign, which is referred to as Operation Cloud Hopper, has significantly affected UK organisations. Researchers reported that data exfiltrated often relates to employees, customers and suppliers. Probably, the group selects certain tools to attack specific regions. Industry data indicates that in the UK the actor has been principally using the QuasarRat malware. The actor has been observed deploying Quasar RAT in two components: one to decrypt the payload (DILLJUICE) and the other to install the RAT as a service (DILLWEED). In some cases the actor has also used the certutil command to decode data and the psping command to check connectivity. When access to a network is achieved, the actor commonly compromises domain administration credentials for the entire network. The compromised data is sent in .RAR files, which are deleted from the victim's machine once exfiltration has been achieved.

The actor has also been observed in some cases deploying cryptomining software, likely as a tactic to distract network administrators and incident responses teams from the RAT activity. The cryptomining software used does change over time via a control channel although the exact reasons for this are unclear.

The report also indicates that the actor used phishing attacks to deliver the Cobalt Strike tool.

APT10 is a China-based threat actor, which has been active since at least December 2009. Since then it has targeted construction, engineering, aerospace, and telecommunications industries and government institutions for espionage purposes. The group has been primarily focused on Japanese organizations. Also, their attacks affected organizations in the following countries: India, South Africa, South Korea, Sweden, the United States, Canada, Australia, France, Finland, the United Kingdom, Brazil, Thailand, Switzerland, and Norway.

APT name	Regions attacked	Operation start
Targeted attacks using an updated versions of Shamoon	Europe, Middle East	December 2018

In December 2018, researchers observed a new variant of the infamous Trojan Shamoon (aka Disttrack) attacking several sectors, including oil, gas, energy, telecom and government organizations in the Middle East and southern Europe.

An Italian oil and gas company Saipem announced that servers from its offices in multiple countries were hit with a new Shamoon variant. In addition, Saipem is the largest foreign contractor of Saudi Aramco, Saudi Arabia's national oil and gas company, which was also attacked using this wiper back in 2012.

The attack reportedly affected between 300 and 400 servers and up to 100 personal computers.

Chronicle cyber security experts reported that the version of Shamoon used to launch cyber attacks against Saipem is anomalous. First of all, the list of command and control servers (C2) is blank. Furthermore, pre-programmed domain credentials are also missing.

Unlike previous Shamoon attacks, this version does not replace the destroyed files with an image. Instead, it overwrites the master boot record (MBR), partitions and files in the system with random data.

Specialists discovered 3 modules used in the attack:

1. A dropper is responsible for installing a communications and wiper modules to the system. The dropper is also responsible for spreading to other systems on the same local network. This is accomplished by attempting to log into other systems on the network remotely using previously stolen usernames and passwords. The strain used in this attack does not contain any domains, usernames, or passwords to perform the spreading functionality, meaning that it relied solely on manual deployment.
2. A wiper module that the dropper installs to the system is responsible for overwriting the data within the MBR, partitions, and files on the system. It carries out the data wiping using a legitimate hard disk driver called RawDisk by ElDos.
3. The communications module is responsible for reaching out to hardcoded URLs to communicate with the command and control (C2) server.

Experts at Symantec suggest that there is a link between Shamoon and the APT33 group (Elfin). APT33 is believed to be an Iran-based state-sponsored actor. The group uses the StoneDrill Trojan, which has many similarities to the Shamoon wiper.

APT name	Regions attacked	Operation start
Charming Kitten	USA	October 2018

Security researchers observed Charming Kitten's attempts to break into the email accounts of US Treasury officials tasked with enforcing economic and military sanctions against the Islamic Republic of Iran.

Also on the hackers' hit list: high-profile defenders, detractors and enforcers of the 2015 nuclear deal struck between Washington and Tehran, as well as Arab atomic scientists, Iranian civil society figures and D.C. think tank employees.

Certfa Lab researchers reported that the campaign was related to new sanctions imposed on Iran by the U.S. in November 2018.

The hit list surfaced after Charming Kitten mistakenly left one of its servers open to the Internet. Researchers at Certfa found the server and extracted a list of 77 Gmail and Yahoo addresses targeted by the hackers. Currently, it is not clear how many of the accounts were successfully compromised

Security specialists say that the attackers are utilising different methods to carry out their attacks. These methods can be put into two categories:

- Phishing attacks through unknown email or social media and messaging accounts
- Phishing attacks through email or social media and messaging accounts of public figures, which have been hacked by the attackers

Researchers also discovered that the hackers have collected information on their targets prior to the phishing attack. The hackers design specific plans for each target based on the level of targets' cyber knowledge, their contacts, activities, working time, and their geographic situation.

Charming Kitten (aka Parastoo, iTittens, MacDownloader, NEWCASTER, NewsBeef, APT35, Group 83) has been operating since 2014 and is allegedly connected with the Iranian government. The group uses watering hole attacks and fake social media profiles, primarily targeting individuals of interest to Iran, who are involved in academic research, human rights, and the media.

APT name	Regions attacked	Operation start
Hackers stole EU diplomatic cables	EU countries	2015

Area 1 Security researchers announced discovery of an ongoing cyber campaign that has gained access into the diplomatic correspondence network of the European Union.

Unusual behavior was first spotted in April 2015. The firm suspected a cyberattack was taking place against Intergovernmental Organizations, Ministries of Foreign Affairs and Ministries of Finance, as well as trade unions and think tanks.

After tracking the suspected campaign for some time, in November 2018, Area 1 uncovered the successful infiltration of the Ministry of Foreign Affairs of Cyprus and therefore the COREU network, a key system which provides the backbone of communications between all 28 EU countries.

Initial access was gained after phishing attempts successfully obtained credentials belonging to network administrators and senior members of staff. This stolen data was then used to implant malware on the network designed to create a backdoor and establish a path with a command-and-control (C2) network for data exfiltration. In one case of infection, the Remote Access Trojan (RAT) PlugX was used.

The diplomatic cables accessed by hackers were marked as LIMITE/LIMITED or RESTRICTED/RESTRAINT. The LIMITE stamp is assigned to confidential correspondence, the disclosure of which may have adverse consequences for the European Union or its member countries; RESTRAINT means information that threatens the key interests of the EU, as specified in the official documents of the Union.

APT name	Regions attacked	Operation start
Targeted attack exploiting a 0-day vulnerability CVE-2018-15982	Russia	November 2018

In late November 2018, an unknown threat actor conducted an attack on Polyclinic №2 of the Administration of the President of the Russian Federation.

The attacker used spear-phishing emails with an attached decoy document that appeared as a well-designed employee questionnaire. The document exploited a recent Flash 0day CVE-2018-15982, and deploy a customized Trojan with self-destruction functionality.

The multidisciplinary outpatient institution mainly serves the civil servants of the highest executive, legislative, judicial authorities of the Russian Federation, as well as famous figures of science and art. This fact may indicate that they were the final target of the attackers.

The malicious campaign was named Operation Poison Needles. The attacker launched the attack through a RAR compressed package. If the victim, who opened such a document, allowed the execution of Flash Active X, the malicious code elevated its privileges and accessed the JPG file, which was also part of the mentioned archive. Another RAR archive was embedded at the end of the image. An EXE file was extracted from this archive, which was executed in the system, disguised as the Nvidia Control Panel and was the simplest backdoor Trojan.

APT name	Regions attacked	Operation start
APT-C-35	Pakistan	May 2018

The Donot APT group, also known as APT-C-35, has been targeting a Pakistani businessman working in China since May. The group sends the victim a macros-laden Excel file as an attachment in a spear phishing email. Once the victim enables macros, it installs a loader that drops other backdoor, keylogging, and downloader plugins.

The Excel lure document is pretending to be a single BMW car price list.

APT-C-35 is a cyber espionage group that primarily targets government agencies in Pakistan.

APT name	Regions attacked	Operation start
Stolen Pencil	USA, Asia	May 2018

The ASERT team discovered a cyber espionage campaign, named Stolen Pencil, conducted by an unknown hacking group that has used a Google Chrome extension to infect victims and steal passwords and cookies from their browsers.

The group has been active since at least May 2018. Hackers used spear-phishing emails to lure victims on websites copied from legitimate academic organizations. These phishing sites, now down, showed a benign PDF document but prevented users from viewing it, redirecting victims to the official Chrome Web Store page to install a (now removed) Chrome extension named Auto Font Manager.

Researchers reportedly identified three universities based in the United States and one non-profit institution based in Asia that are believed to have been targeted. A large number of the victims, across multiple universities, had expertise in biomedical engineering, possibly suggesting a motivation for the attackers' targeting.

Researchers link this campaign to a North Korean APT group, possibly a cyber-espionage group known as Kimsuky.

APT name	Regions attacked	Operation start
Gamaredon Group	Ukraine	November2018

In November 2018, The Computer Emergency Response Team of Ukraine (CERT-UA) detected a new strain of the Pterodo Windows backdoor targeting computers at Ukrainian government agencies. The Pterodo backdoor sets up the hidden access to computer systems for the use or control in the future, which may lead to leakage of information, to block the operation of, data encryption and other malicious activity.

The malware was delivered through spear-phishing emails masqueraded as messages from http://gov.ua.

Experts note that the main difference of new modifications from previous versions is that the system can become infected via flash drives and other removable storage media, as well as flash drives connected to the affected machine could be infected for further malware distribution.

In addition, in this version, for each affected system, an individual URL directory with the serial number of the drive on which the system is established. This indicates that the attackers analyze the information received about the infected system and, individually for each system, determine which new applications to load and launch

The Pterodo backdoor belongs to the arsenal of Gamaredon Group. This threat actor is a Russian-speaking cybercriminal group that has been active since 2013. Initially the group used borrowed tools to conduct attacks, and later began to actively use custom developed malware. Their attacks target government institutions, law enforcement agencies and military organizations, primarily in Ukraine.

APT name	Regions attacked	Operation start
Kimsuky	South Korea	October 2018

In October 2018, the Kimsuky group launched a new wave of attacks on South Korea. The campaign was called Operation Black Limousine.

Like in previous attacks, the attackers used HWP files in spear-phishing campaigns. The shellcode found in the document is almost identical to the one used in previous attacks. Based on the documents used, the attackers conducted attacks for cyber espionage purposes. The documents referred to regulations related to national research and development projects.

The file contains 'BIN0001.eps' malicious Post Script. This script contains a malicious shellcode, which will attempt to connect to another command-control (C2) server.
The internal shellcode is encrypted. Once decrypted, it attempts to communicate with a Korean website (rentcartoday.com).

If communication with the C&C server is successful, additional malicious code is downloaded and executed. Execution of this code can lead to damage such as computer data leakage and remote control.

Kimsuky (aka Velvet Chollima) is a hacking group, which is believed to be based in North Korea. Since 2010, they have been attacking South Korean organizations.

APT name	Regions attacked	Operation start
APT37	South Korea, Russia, Cambodia	July 2018

In Q4 2018, another North Korean cybercrime group, APT37, was active. The attackers exploited an unknown vulnerability in the Hancom Office suite, targeting South Korean activists.

Hancom Office Suite is an Office document processing software that is highly popular in South Korea.

Experts found that “User1” was the last person to save the file, and the author of the document was “gichang”. The campaign was called Operation Korean Sword.

After the HWP sample is opened, no request to enable macro will appear. Instead, it will silently add the malicious script UpgradeVer45.bat in the current user's startup directory, and create the files Dhh01.oju01 and Dhh02.oju01 ((MZ signatures) in the %AppData% directory.

The final payload, packed using Themida encryption software, is a remote control Trojan of the ROKRAT family.

In November 2018, specialists discovered a new malicious HWP document. When it is launched, an unknown vulnerability is displayed as a damaged file, and the EPS vulnerability code is executed. The file was created on November 16, 2018, and the 'BinData' stream contains 'BIN0001.eps' PostScript code.

PostScript will create the 'MemCacheLog24.vbs' script in the startup program path and will execute the 'Cache51.bat' batch file. It will also create two files "Pemn01.hje01" and "Pnn02.hje01" in the %APPDATA% path,

which are combined into the 'MemoryOrder85584031.com' file and executed. The final payload is a remote access tool ROKRAT. The payload collects the infected system's information and uses the Yandex token to retrieve the attacker's additional commands.

In addition, researchers have discovered a link between the NOKKI malware family and APT37. Security specialists recently observed NOKKI-laden attacks targeting Russian- and Cambodian-speaking individuals with political lures. NOKKI is a backdoor, first observed between January 2018 to May 2018, using a remote FTP server to receive commands and download additional modules. Newer versions of NOKKI then started appearing in June 2018 – these use HTTP.

According to Unit 42, NOKKI used malicious macros within a Microsoft Word document in a new attack wave. The deobfuscation technique used in the attack was unique. To avoid detection, the macros employ simple obfuscation of interesting strings that ultimately just used base64 encoding. However, it used a somewhat unusual method where it would first convert the base64-encoded text into hex, and then convert that hex into a text string.

After looking for other samples that use this deobfuscation technique, Unit 42 researchers were able to uncover only one other malware that does: a RAT called DogCall, which has been attributed to the APT37 threat group. The DogCall sample was found in a decoy file that targeted individuals interested in the World Cup hosted in Russia in 2018. The deobfuscation routine used between the sample and the NOKKI campaigns was identical. When the chain of execution completes, a DogCall malware sample is executed on the victim's machine.

The malware sample downloads and executes a remote VBScript file wrapped in HTML and appends text to the original Word document to provide the lure for the victim. VBScript writes data to the file %APPDATA%\Microsoft\mib.dat. This file will later be used by the newly discovered Final1stspy malware family.

Final1stspy is a dropper malware family. It eventually calls the final payload: DogCall.

DogCall is able to perform the following actions on the victim's machine:

- Take screenshots
- Keylogging
- Capture microphone data
- Collect victim information
- Collect files of interest
- Download and execute additional payloads

The malware uploads the stolen data to third-party cloud storage providers. The sample identified in the wild is configured to upload to pCloud, but functionality to upload to Dropbox, Box and Yandex Cloud is also included.

APT37 (aka Group123, Reaper, ScarCruft, Geumseong121, Red Eyes) is a suspected North Korean cyber espionage group that has been active since at least 2012. The group has targeted victims primarily in South Korea, but also in Japan, Vietnam, Russia, Nepal, China, India, Romania, Kuwait, and other parts of the Middle East.

APT name	Regions attacked	Operation start
Gallmaker	Eastern Europe, Middle East	December 2017

Symantec researchers have uncovered a previously unknown cyber espionage group dubbed Gallmaker that is targeting government and military organizations across the world. It is interesting to note that the group doesn't

use malware to gain access to and control Windows systems; instead using legitimate tools like Metasploit and PowerShell to gain access to information.

The group has been operating since at least December 2017. Their targets include several overseas embassies of an Eastern European country, and military and defense targets in the Middle East.

Attacks begin with spear-phishing emails used to deliver documents with names related to government, military, or diplomatic themes. These malicious lures take advantage of an exploit in Microsoft Office Dynamic Data Exchange (DDE) protocol to gain access to machines. The DDE protocol can be used for legitimate purposes to send messages between Microsoft applications that share data through shared memory, e.g. to share data between Excel and Word.

After gaining access to a system, the attackers use legitimate processes and tools. For example, WindowsRoamingToolsTask is used to schedule PowerShell scripts and tasks. The attackers use Metasploit to obfuscate shellcode that is executed via PowerShell. A legitimate version of the WinZip console creates a task to execute commands and communicate with the command-and-control (C&C) server. The Rex PowerShell library helps create and manipulate PowerShell scripts for use with Metasploit exploits. There is also evidence that the group is deleting some of its tools from victim machines once it is finished, to hide traces of its activity.

APT name	Regions attacked	Operation start
Inception	Europe	October 2018

In October 2018, Unit 42 specialists observed attacks using CVE-2017-11882 and a new PowerShell backdoor, called POWERSHOWER, against European targets.

The attacks are attributed to the Inception group, which has been active since at least 2014. Historical attacks used custom malware for a variety of platforms, and targeting a range of industries, primarily in Russia, but also around the world.

The main distinguishing feature of the recent attacks is the use of “Remote Templates”. Remote templates are a feature of Microsoft Word, which allows a document to load a template to be used in the document – this template can be externally hosted, either on a file share, or on the Internet. The template is then loaded when the document is opened.

When opened, the documents display decoy content and attempts to fetch a malicious remote payload via HTTP. The decoy content is usually copied from media reports, often with political themes in the target regions.

In most cases, the C&C server did not return a malicious template, however researchers recently observed two cases where a malicious template containing two exploits was served. In both cases the template contained exploits for both CVE-2012-1856 and CVE-2017-11882, which target vulnerabilities in Word disclosed and patched in 2012 and 2017 respectively.

The payload for the exploits was VBScript in an OLE package object, which in turn decodes and executes POWERSHOWER, a simple PowerShell backdoor.

POWERSHOWER allows the attacker to:

- Fingerprint the machine, and upload this information to the initial C&C.
- Clean up a significant amount of forensic evidence from the dropper process, as we detail below.
- Run a secondary payload, if the attacker decides the target machine is sufficiently interesting

APT name	Regions attacked	Operation start
Sidewinder (T-APT-04)	Pakistan	October 2018

In Q4 2018, Sidewinder group continued their cyber espionage activities.

The threat actor used a decoy document, which exploited the CVE-2017-11882 vulnerability. The vulnerability affects the Microsoft Equation Formula Editor (a specialized program for creating and editing mathematical formulas, EQNEDT32.EXE) and makes it possible to execute arbitrary commands without user's involvement.

This time, the Sidewinder group abandoned HTA files with PowerShell in favor of VBS. The purpose of this change is to be more furtive. The HTA file checks with WMI whether the anti-virus solutions are installed on the victim's computer and sends this information to the C&C server. If no anti-virus product is detected, the payload launches the RAT.

Sidewinder APT group is believed to be of Indian origin, and their earliest attacks are attributed to 2012. They primarily focus on cyber espionage against military targets in South Asian countries such as Pakistan.

APT name	Regions attacked	Operation start
APT-C-27	Arab countries	2018

Researchers at 360 Total Security have discovered a new attack attribute to the APT-C-27 group. The threat actor has long been engaged in cyber-attacks against Arab countries such as Syria. It mainly uses APK, PE, VBS, JS files as attack vectors, involving Android and Windows platforms, using social networks and spear phishing email to spread malicious payloads.

From the sample captured by 360 CERT, the attack started with the Office phishing document containing the Package object.

The bait file shows an official letter issued by UNRWA (The United Nations Relief and Works Agency for Palestine Refugees in the Near East). After the victim executes the embedded Package object, another Word document <الذاتية السيرة> is displayed. Once the user double clicks on the object, the embedded VBS script will be released and executed.

The script under the Word process is a Dropper, which releases the VBA backdoor and the <الذاتية السيرة> document executed in the next stage. Then, it uses the backdoor script to interact with C2.

Unlike the common attack process, there is no PE file in the entire attack chain, and the APT-C-27 group chooses to use the script to communicate directly with C2.

Data leaks

GROUP IB

GLOBAL CYBER SECURITY COMPANY

- Quora's knowledge sharing service administration announced a data leak of 100 million users as a result of a hacker attack. Unknown cybercriminals infiltrated the company's network and gained access to the following personal user data: names, email addresses, encrypted passwords, non-public content and actions on Quora.com, e.g. answer requests, downvotes, and direct messages, as well as data from linked social networks.
- HSBC Bank confirmed a data breach occurred between October 4-14 affecting its U.S. customers' information. The attackers accessed a glut of personal information including account numbers and balances, statement and transaction histories, payee details, names, addresses and birth dates. It is reported that the leak affected less than 1% of bank customers. The bank does not disclose the details of the attack. But cybersecurity experts said that the attackers used the "credential stuffing" method — using credentials stolen from other resources. After the attack, HSBC implemented additional layers of security by introducing multi-factor authentication for online banking accounts and the CAPTCHA security service at log-in to test whether users are machines or humans.
- In late October, the Hong Kong airline Cathay Pacific confirmed that it suffered a major data leak affecting up to 9.4 million passengers in May 2018. The following personal data was accessed: passenger name, nationality, date of birth, phone number, email, address, passport number, identity card number, frequent flyer programme membership number, customer service remarks, and historical travel information. No passwords are thought to have been accessed.
- The hotel group Marriott International said the guest reservation database of its Starwood division had been compromised by an unauthorised party. The private information of up to 500 million guests may have been accessed as part of the breach. The world's largest hotel chain said it first received an alert on September 8 from an internal security tool of an attempt to access the database in the United States. As part of an investigation, the company discovered there had been unauthorized access since 2014 and that an "unauthorized party" had copied and encrypted information. For about 327 million of the guests, the information includes some combination of a name, mailing address, phone number, email address, passport number, date of birth, gender, arrival and departure information, and reservation date. This incident is believed to be one of the largest breaches to hit the hospitality industry ever.
- In October, the US Department of Defense confirmed that personal information and credit card data of some 30,000 U.S. personnel has been compromised in a breach affecting a DoD's third party contractor. A Pentagon spokesman does not name the hacked vendor due to security reasons, as the investigation is still ongoing.